Analyse d’impact sur la protection des données

Cas G - Souris ergonomique connectée
Équipe 2 | Version préparatoire du 16 octobre 2026

Périmètre retenu : données conservées sur l’ordinateur de la personne qui utilise la souris. Historique disponible pendant le suivi, avec suppression à tout moment.

La question adaptée à notre projet

La souris collecte des signaux physiologiques et des mouvements pendant son utilisation. Leur rapprochement avec les horaires et les sessions peut révéler des habitudes ou des informations de santé. Qui peut lire les fichiers sur le PC ? Quelles mesures sont réellement nécessaires au suivi ? Comment l’utilisateur consulte-t-il, exporte-t-il et supprime-t-il son historique ?

Traitement et personnes concernées

Le prototype R3 acquiert et affiche des mesures expérimentales. La finalité future envisagée est une aide au professionnel pour la prise en charge des troubles musculosquelettiques (TMS), chez un adulte utilisant un ordinateur, en suivi non urgent. Le logiciel actuel ne fournit pas de recommandation médicale validée ni de décision thérapeutique automatique. [P1]

Données présentes dans R3	Utilité et limites
Pouls calculé, SpO2 expérimentale, signaux optiques IR/rouge, qualité PPG	Mesures au contact de la main. Leur utilité pour les TMS reste à démontrer.
GSR, accélérations de la souris, température de contact	Pas de diagnostic de stress, pas d’angle anatomique du poignet, pas de température centrale.
Horodatages, session et connexion, états et erreurs techniques	Relier les mesures et diagnostiquer une acquisition. Les identifiants de session ne rendent pas les données anonymes.

Circulation des données

Capteurs de la souris → liaison Bluetooth LE → passerelle sur le PC → fichier CSV local → tableau de bord local. Le code comporte une option MQTT vers 127.0.0.1:1883. Aucun serveur distant n’est retenu dans le périmètre. Les sauvegardes du PC et l’exposition réseau du tableau de bord restent à vérifier. [P1]

L’analyse de risques du dispositif (tableau n° 1 à 22) traite les défaillances, erreurs et dommages. Cette analyse d’impact examine aussi la nécessité de la collecte, les droits et les effets sur la vie privée. Une même faiblesse peut contribuer aux deux analyses.

Nécessité, accès et conservation

Minimiser la collecte

Pour chaque capteur, préciser l'indicateur recherché et la décision de suivi qu'il permet. Si aucune utilité n'est démontrée, désactiver la collecte correspondante ou la limiter aux essais techniques. Une souris utilisable sans enregistrement doit rester possible. Ne pas déduire un état de santé, un stress ou une productivité à partir d'un signal non validé.

Ne demander ni nom, ni adresse, ni identité de patient pour le simple affichage local. Séparer les utilisateurs et les sessions. L'absence de nom dans un CSV ne garantit pas l'anonymat : le PC, les horaires et le contexte peuvent identifier la personne. Les mesures physiologiques peuvent relever des données de santé selon leur nature, leur croisement et leur finalité. [P1, P2]

Règle de conservation retenue

L'historique de suivi reste sur le PC pendant la durée du suivi. L'utilisateur peut supprimer une période ou l'ensemble des données à tout moment. À la fin du suivi, prévoir la suppression après possibilité d'export. Une désinstallation doit proposer explicitement de conserver ou de supprimer les données locales.

Ce choix s'inspire du fonctionnement de Santé d'Apple et de Fitbit/Google Health : l'historique peut durer plusieurs années et sa suppression est contrôlée par l'utilisateur. Il ne s'agit pas d'une durée légale commune aux objets connectés. Pour le projet, la conservation doit rester justifiée par la finalité du suivi. [P3-P5]

Catégorie	Règle à mettre en place
Historique utile au suivi	Durée du suivi, suppression possible à tout moment et prévue à sa clôture. Ne pas conserver par défaut des données sans utilité pour cet historique.
Signaux bruts et diagnostics	Définir une durée technique distincte et courte avant les essais. Cette durée doit répondre au besoin de validation ; elle ne limite pas l'historique de suivi.
Exports et sauvegardes	Identifier les copies. Informer que supprimer l'historique principal ne supprime pas un export réalisé ailleurs. Prévoir la purge des sauvegardes gérées par le projet.

Écart actuel : la passerelle ajoute les enregistrements au CSV. Le code examiné ne fournit ni purge par ancienneté, ni interface de suppression de l'historique, ni clôture du suivi. Les règles ci-dessus sont des exigences à développer et tester. [P1]

Accès, information et droits

Accès prévu : utilisateur du PC. Aucun accès automatique de l'équipe, d'un employeur ou d'un professionnel. Un éventuel partage médical doit être choisi et limité par l'utilisateur. Prévoir une notice indiquant les données, les finalités, les destinataires, la conservation et le moyen d'exercer ses droits. Permettre consultation, export et suppression ; signaler une mesure incorrecte sans falsifier la mesure d'origine. [P6]

Risques pour les droits et libertés

Estimations qualitatives préparatoires : « importante » signifie une atteinte pouvant avoir des conséquences personnelles ou professionnelles durables ; « modérée », une gêne réversible dans le suivi. « Possible » décrit un scénario plausible sans fréquence mesurée. Aucune cotation résiduelle n'est validée avant les essais. Ce repérage ne reprend pas la matrice de sécurité du TP.

A1. Lecture non autorisée du fichier local

Scénario et faiblesse. Un proche, un autre compte du PC, un administrateur ou un logiciel malveillant lit le CSV. Les droits du dossier, le chiffrement du disque et les sauvegardes n'ont pas été vérifiés. [P1]

Impact pour la personne. Divulgation d'habitudes et d'informations de santé, gêne, détresse ou utilisation défavorable de ces informations.

Estimation initiale. Gravité importante ; vraisemblance possible, dépendante de la configuration du PC.

Mesures proposées. Dossier privé au compte utilisateur, verrouillage de session, chiffrement du disque, protection des sauvegardes, limitation des exports. Aucun fichier de mesures réelles dans Git.

Vérification attendue. Essayer l'accès depuis un autre compte standard ; vérifier les permissions, le chiffrement et les destinations de sauvegarde. Lien : risque 9 du TP.

A2. Transmission ou service local exposé

Scénario et faiblesse. Une configuration Bluetooth insuffisante ou un tableau de bord/broker exposé sur le réseau permet à un tiers de consulter les mesures. La sélection BLE par nom ne démontre pas l'authentification. L'option MQTT vise actuellement localhost ; son existence ne prouve pas une fuite distante. [P1]

Impact pour la personne. Interception de données intimes et surveillance à l'insu de la personne.

Estimation initiale. Gravité importante ; vraisemblance possible, protections réelles à tester.

Mesures proposées. Vérifier appairage et chiffrement BLE. Limiter le tableau de bord et le broker à l'interface locale. Désactiver MQTT si inutile. Réévaluer toute ouverture distante.

Vérification attendue. Contrôler les interfaces d'écoute et tester depuis une autre machine ; vérifier qu'un client BLE non autorisé ne peut lire les mesures. Lien : risque 9.

A3. Données attribuées à la mauvaise personne

Scénario et faiblesse. Plusieurs acquisitions s'ajoutent au même CSV ; les courbes ne filtrent pas les sessions. Une personne voit ou exploite l'historique d'une autre. Une usurpation d'objet constitue aussi un scénario distinct. [P1]

Impact pour la personne. Divulgation croisée, profil inexact et perte de maîtrise du suivi ; conséquences possibles sur une future prise en charge.

Estimation initiale. Gravité importante ; vraisemblance possible si le PC ou la souris est partagé.

Mesures proposées. Séparer les profils/fichiers, filtrer par session, afficher l'utilisateur actif et authentifier l'objet. Ne pas assimiler un UUID de session à une identité vérifiée.

Vérification attendue. Enchaîner deux profils et deux sessions ; vérifier l'absence de mélange et le refus d'une source étrangère. Liens : risques 10 et 14.

Conservation, détournement et perte

A4. Historique oublié ou suppression incomplète

Scénario et faiblesse. Le fichier continue à grossir après la fin du suivi, ou réapparaît depuis une sauvegarde. La purge n'existe pas dans la passerelle examinée. [P1]

Impact pour la personne. Exposition prolongée de données intimes et impossibilité pratique de maîtriser leur devenir.

Estimation initiale. Gravité importante ; vraisemblance forte si l'usage se prolonge sans règle de clôture ni action manuelle.

Mesures proposées. Ajouter suppression par période/totale, clôture du suivi et règles pour les copies gérées. Réexaminer périodiquement le besoin de garder l'historique. Ne pas recopier des bruts inutiles dans les synthèses.

Vérification attendue. Supprimer un jeu fictif, relancer l'application puis restaurer une sauvegarde de test : vérifier que les données supprimées ne sont pas réintroduites sans contrôle. Lien : risque 9.

A5. Réutilisation pour surveiller ou évaluer

Scénario et faiblesse. Des horaires et signaux initialement collectés pour le suivi sont interprétés comme des indicateurs de présence, de stress ou de performance puis transmis à un tiers. Ce scénario est hypothétique : cette fonction n'est pas fournie par le prototype. [P1]

Impact pour la personne. Pression, perte d'autonomie, discrimination ou conséquences professionnelles sur la base d'un profil non fiable.

Estimation initiale. Gravité importante ; vraisemblance possible uniquement en cas de partage ou de changement de finalité.

Mesures proposées. Limiter la finalité au suivi défini. Exclure les tableaux de productivité et le partage automatique. Expliquer les limites des inférences et réévaluer tout nouveau destinataire.

Vérification attendue. Examiner les écrans et exports ; vérifier qu'ils ne produisent pas de score de stress, de diagnostic ou de rendement. Faire relire la notice par un utilisateur.

A6. Perte ou altération de l'historique

Scénario et faiblesse. Panne du PC, corruption du CSV, modification manuelle ou données incohérentes rendent l'historique incomplet ou trompeur. Le stockage local ne fournit pas à lui seul une sauvegarde ni une preuve d'intégrité. [P1]

Impact pour la personne. Perte de données utiles au suivi, impossibilité de les consulter ou de les transmettre correctement ; décisions ultérieures fondées sur des informations fausses.

Estimation initiale. Gravité modérée dans le suivi expérimental non urgent ; à réévaluer si l'historique devient déterminant pour une prise en charge. Vraisemblance possible.

Mesures proposées. Sauvegarde locale chiffrée choisie par l'utilisateur, contrôle de cohérence, séparation des sessions, indication des lacunes et traçabilité des corrections.

Vérification attendue. Simuler corruption et restauration avec données fictives ; vérifier absence de faux état rassurant et restitution du bon historique. Liens : risques 1, 4, 14, 17 et 18.

Résiduel A1 à A6 : non validé. Les mesures sont proposées ; leur présence dans ce document ne démontre pas leur mise en œuvre. Les résultats des contrôles doivent être consignés avant l'acceptation des risques.

Décision et références

Une AIPD est-elle obligatoire ici ?

Le seul fait de garder les données sur un PC personnel ne répond pas à cette question. Un usage strictement personnel ou domestique peut relever de l'exception de l'article 2 du RGPD. Une collecte organisée par l'équipe, un établissement ou un professionnel doit être évaluée dans son propre cadre. [P7]

La liste CNIL vise notamment certains traitements de santé en établissement et la surveillance constante des employés. Ces situations ne sont pas établies pour ce prototype individuel. En revanche, les données sensibles et un suivi systématique rendent l'examen des critères AIPD nécessaire avant un déploiement organisé. Le contexte des patients, l'échelle et les destinataires restent à préciser. [P8, P9]

Conclusion du dossier : conserver cette analyse préparatoire et compléter l'examen d'obligation. Ne pas déclarer une AIPD réglementaire validée. Si un risque élevé subsiste malgré les mesures, le responsable doit examiner la consultation préalable de la CNIL. [P9]

Actions restant à attribuer et vérifier

1. Identifier le responsable du traitement et le contact pour les droits. Pour une collecte encadrée, documenter la base de l'article 6 et la condition de l'article 9 applicable ; ne pas présumer qu'un accord informel suffit. [P10]
2. Justifier chaque mesure conservée, arrêter la durée des bruts et publier la notice.
3. Mettre en œuvre les accès, la séparation des sessions et la suppression de l'historique.
4. Réaliser les essais A1 à A6 sur données fictives ; compléter les niveaux résiduels et recueillir l'avis des utilisateurs. Associer le DPO s'il est désigné.
5. Faire dater la décision par le responsable et réviser le dossier si serveur, nouveaux destinataires ou usage clinique sont ajoutés.

Sources consultées le 16 octobre 2026

P1. Projet : code R3, gateway.py et dashboard.py (révision f76c7e4)

P2. CNIL : définition des données de santé

P3. Apple : Health App & Privacy, rubrique Retention

P4. Google : confidentialité Google Health, durée des données

P5. CNIL : durées de conservation

P6. CNIL : droits des personnes

P7. RGPD : article 2, champ d'application

P8. CNIL : liste des traitements exigeant une AIPD

P9. CNIL : principes et réalisation d'une AIPD

P10. CNIL : formalités pour les données de santé

Éléments projet : choix de stockage et d'historique confirmés par l'utilisateur ; lecture du code et du dossier technique. Aucun résultat de test de sécurité du PC, aucun avis DPO et aucune acceptation réglementaire ne sont présumés.